



**Disclaimer:** This document is provided for informational and educational purposes only as part of GRC Mastery training course. While we have made reasonable efforts to ensure the accuracy of the information contained herein, it is not intended to be professional advice. We make no warranties or representations of any kind, express or implied, regarding the accuracy or completeness of the information provided. You should not rely on this document for any commercial decision-making. By using this document, you agree to hold us harmless from any and all damages or losses arising from your use of this document.



# Incident Management Policy

| Date | Version | Author | Description | Approved By | Last Updated | Review Frequency | Next Review |
|------|---------|--------|-------------|-------------|--------------|------------------|-------------|
|      |         |        |             |             |              |                  |             |
|      |         |        |             |             |              |                  |             |
|      |         |        |             |             |              |                  |             |



## Purpose

This policy ensures that Stark Industries Inc. can detect, report, assess, respond to, and recover from information security incidents in a timely, coordinated, and consistent manner. This policy is aligned with ISO/IEC 27001:2022 (A.5.28 - A.5.31).

## Scope

Applies to all employees, contractors, third-party vendors, and systems under the ISMS scope of Stark Industries Inc., including production environments, cloud infrastructure (AWS), developer tools, and endpoint devices.

## Definitions

| Term           | Definition                                                                                                                             |
|----------------|----------------------------------------------------------------------------------------------------------------------------------------|
| Incident       | An event that has or may compromise the confidentiality, integrity, or availability of information or systems                          |
| Major Incident | Any incident that significantly disrupts business operations, affects multiple users, or could result in legal/regulatory consequences |
| Security Event | Observable occurrence (e.g. alert, log entry) that may indicate a security incident                                                    |

## Policy Objectives

- Detect and respond to incidents quickly and effectively
- Minimise business disruption and data loss
- Fulfil legal, regulatory, and contractual obligations
- Maintain accurate incident records for accountability and continuous improvement

## Incident Reporting (A.5.29)

All incidents must be reported via:



- Email to [security@starkindustries.com](mailto:security@starkindustries.com)
- Internal Slack channel #security-incidents

Reports must include:

- Description of the issue
- Time and location
- Systems and users affected
- Any known actions taken

## Incident Response Process

| Stage           | Action                                                             |
|-----------------|--------------------------------------------------------------------|
| Detection       | Monitor logs, alerts, and user reports                             |
| Assessment      | Validate and classify the incident (Low, Medium, High, Critical)   |
| Containment     | Isolate affected systems, accounts, or services                    |
| Eradication     | Remove root cause (e.g. patching, access revocation)               |
| Recovery        | Restore systems to a secure operational state                      |
| Notification    | Inform internal stakeholders, customers, or regulators as required |
| Lessons Learned | Conduct post-incident review and update controls (A.5.31)          |

## Classification Guidelines

| Level    | Description                                                                   |
|----------|-------------------------------------------------------------------------------|
| Low      | Minimal impact, handled by IT with no customer effect                         |
| Medium   | Limited disruption, some user accounts or internal systems affected           |
| High     | Customer-facing impact, potential breach of confidential data                 |
| Critical | Severe system compromise, legal or regulatory implications, widespread outage |



## Communication and Escalation

- Internal escalation follows the ISMS contact chain
- Legal or PR teams must be informed for incidents involving data breaches or media risk
- Customers must be informed if their data is affected, following contractual or regulatory timelines.

## Evidence Handling and Logging

- Incident-related logs must be preserved and secured
- Screenshots, network captures, and audit trails are stored in a restricted-access incident evidence folder

## Training and Awareness

- All staff must complete incident reporting awareness training **annually**
- Technical teams participate in tabletop exercises or incident simulations every 12 months

## Testing and Continuous Improvement

- Incident response procedures must be tested **at least annually**
- Every major incident must result in a formal **post-incident report**, including root cause, corrective actions, and ISMS control updates

## Roles and Responsibilities (A.5.28)

| Role                               | Responsibilities                                                                         |
|------------------------------------|------------------------------------------------------------------------------------------|
| All Users                          | Report suspected incidents immediately via the designated channel                        |
| Incident Handler (InfoSec Analyst) | Lead technical response and evidence collection                                          |
| Information Security Manager       | Approve severity classification, coordinate escalation, ensure response plans are tested |
| GRC Analyst                        | Maintain incident register and support post-incident reviews                             |



## Exceptions

- Exceptions must be:
  - Documented
  - Approved by the Information Security Manager
  - Mitigated with alternative controls where feasible

## Policy Review

- This policy is reviewed **annually** or upon significant change to the environment or regulatory requirements.